

MERIDIAN TECHNOLOGIES PVT. LTD.

Internal Policy Document

Data Security Policy

Document Number: IT-POL-002 | **Version:** 3.1 | **Effective Date:** February 2024

Classification: Internal / Confidential

This document is the property of Meridian Technologies Pvt. Ltd. Unauthorized reproduction is prohibited.

Table of Contents

Section	Title
1	Purpose and Scope
2	Data Classification
3	Handling Public Data
4	Handling Internal Data
5	Handling Confidential Data
6	Handling Restricted Data
7	Data Storage and Encryption
8	Data Transfer
9	Data Breach Response
10	Records Retention

1. Purpose and Scope

Objective

This policy defines how all data assets owned, processed, or handled by Meridian Technologies must be classified, stored, transmitted, and disposed of to maintain confidentiality, integrity, and availability.

The policy supports the company's obligations under contracts with clients, applicable laws, and industry standards such as ISO 27001 and the Digital Personal Data Protection Act.

Applicability

The policy applies to all employees, contractors, and third parties handling company or client data, in any form (electronic, paper, verbal) and at any location.

Any deviation must be approved in writing by the Data Protection Officer (DPO) and documented as a risk-accepted exception in the Information Security Risk Register.

2. Data Classification

Tiers

All data is classified into one of four tiers: Public, Internal, Confidential, and Restricted. Owners of each data asset are responsible for accurate classification at creation.

Misclassification, whether by under or over classification, is itself a breach of this policy and may attract disciplinary action.

Tier Definitions

Public: information explicitly approved for public release. Internal: business information for employee use only. Confidential: business-sensitive information including client data and financials. Restricted: highly sensitive personal data, source code of products, regulatory data, and trade secrets.

Where data spans multiple tiers, the highest applicable tier governs handling for the combined asset.

3. Handling Public Data

Release Process

Public data has no handling restrictions but must still be reviewed by the Communications team before external release if it represents the company.

Public data that has been distorted, redacted, or aggregated for release must be reviewed to ensure no Internal or higher data is inadvertently disclosed.

Versioning

All publicly released data must indicate the date of release and a clear point of contact within the company for queries and corrections.

4. Handling Internal Data

Sharing

Internal data may be shared freely with employees on a need-to-know basis. Sharing with vendors or external parties requires an NDA to be in place.

Internal data must not be posted on personal social media, blogs, or any externally facing forum without prior approval from Communications.

Storage

Internal data should reside on company-managed storage. Local copies on laptops are acceptable provided full disk encryption is in place.

5. Handling Confidential Data

Storage Controls

Confidential data must be stored in IT-managed systems with access controls. Local storage on laptops is permitted but must be in the encrypted user profile partition.

Access to Confidential repositories is granted on a least-privilege basis and reviewed every six months by the data owner.

Sharing Controls

Sharing externally requires written approval from the data owner and the use of approved secure channels (encrypted email, secure file transfer, NDA-backed portals).

Forwarding of Confidential email to external addresses is blocked at the gateway and requires explicit allow-listing for approved recipients.

6. Handling Restricted Data

Storage and Access

Restricted data must never be stored on laptops, USB drives, or personal devices. It must reside only on designated secure servers with role-based access and full audit logging.

Access to Restricted data requires explicit written approval from the Data Protection Officer (DPO) and is reviewed quarterly. All access is logged and reviewed monthly.

Handling in Practice

Printing of Restricted data is permitted only on dedicated secure printers with badge release; printed copies must be tracked and shredded after use.

Discussion of Restricted data over public channels (open offices, shared transport, public events) is prohibited.

7. Data Storage and Encryption

Encryption Standards

All laptops and removable media must be encrypted using the company-approved disk encryption tool. Decryption keys are managed centrally by IT Security.

Confidential and Restricted data at rest must be encrypted with AES-256 or stronger. Data in transit must be protected with TLS 1.2 or higher.

Key Management

Encryption keys are stored in a Hardware Security Module (HSM) and access to keys is restricted to authorised IT Security personnel through a dual-control process.

Key rotation occurs at least annually for keys used to protect Restricted data, and on demand whenever a compromise is suspected.

8. Data Transfer

Approved Channels

Approved channels for external transfer of Confidential data: secure file transfer portal, encrypted email (S/MIME or PGP), and DRM-protected document sharing.

Each external transfer must include the appropriate sensitivity label and any necessary recipient handling instructions.

Removable Media

USB devices and removable media for data transfer are blocked by default. Exceptions require approval from IT Security and the data owner, are time-bound, and the device must be encrypted.

Lost or stolen removable media containing company data must be reported immediately to IT Security as a potential data breach.

9. Data Breach Response

Initial Response

Any suspected or confirmed data breach must be reported within 2 hours to the Incident Response Team (irt@meridian.example).

Employees observing a potential breach must not attempt independent investigation; their role is to report promptly and preserve evidence.

Response Plan

The IRT will follow the Data Breach Response Plan: contain, assess, notify the DPO and Legal, notify affected parties as per regulatory requirements, and document for post-incident review.

A formal post-incident review is conducted within 30 days of closure to identify root cause and corrective actions.

Regulatory Notification

Regulatory breach notifications, where applicable (such as under the DPDP Act), must be initiated within 72 hours of confirmation of breach.

Communication with regulators is centralised through the DPO and Legal team; no other employee should communicate with regulators on breach matters.

10. Records Retention

Retention Periods

Internal and Confidential data is retained for 7 years unless a longer period is mandated by regulation or contract. Restricted data retention is governed by the specific contract or law applicable to that data.

Personal data of employees is retained for the duration of employment and 8 years post separation, in line with statutory and tax requirements.

Disposal

On retention expiry, data must be securely disposed of using IT-approved sanitisation methods (cryptographic erasure or physical destruction for media).

Disposal must be evidenced through a Certificate of Destruction issued by IT or the empanelled disposal vendor.